PHOENIX Project — Cybersecurity Threat Analysis

CY005: Apply STRIDE Threat Modelling Framework

Introduction

STRIDE is a structured threat modelling framework developed by Microsoft that provides a systematic method for identifying security threats across all components of a system. Each letter in STRIDE represents a distinct category of threat:

- Spoofing (impersonating a legitimate identity)
- Tampering (modifying data without authorisation)
- Repudiation (denying actions without a traceable audit trail)
- Information Disclosure (exposing data to unauthorised parties)
- Denial of Service (preventing legitimate access to system resources)
- Elevation of Privilege (gaining access beyond authorised permissions).

In the context of the PHOENIX system, STRIDE is applied to each identified entry point and key component to analyse potential threats, understand risks, and support the design of appropriate security controls.

STRIDE Colour Key

S — Spoofing	T — Tampering	R — Repudiation	I — Information Disclosure	D — Denial of Service	E — Elevation of Privilege

STRIDE Analysis — PHOENIX System Components

#	Component	STRIDE Threat	Threat Description	Impact on Phoenix
ST-01	**External Sources of Disasters (BoM / CFA Feed)**	Spoofing	Attacker uses DNS spoofing or a fraudulent TLS certificate to impersonate the Bureau of Meteorology API, feeding Phoenix false hazard severity data as if it were a legitimate official source.	Phoenix receives attacker-controlled disaster data threat monitoring may fail to elevate during a real bushfire or flood event.
ST-02	**External Sources of Cyber Threats & Scams (Scamwatch / ASD Feeds)**	Spoofing	Attacker impersonates a trusted threat intelligence provider (e.g., Scamwatch) using a spoofed API endpoint which causing Phoenix to ingest attacker-controlled scam data as if it were verified intelligence.	Phoenix's AI model is trained and scored against falsified threat intelligence — genuine disaster scams may be misclassified as benign.
ST-03	**DMT User Login (Authentication Portal)**	Spoofing	Attacker uses phished, brute-forced, or credential-stuffed credentials to impersonate a legitimate Disaster Management Team analyst, gaining authenticated access to the Phoenix dashboard and alert approval workflow.	Unauthorised control of alert dispatch, model configuration, and risk threshold settings — a single compromised DMT account can suppress or falsify community alerts.
ST-04	**Alert System (Send Secure Alert / API Dispatch)**	Spoofing	Attacker impersonates Phoenix's official alert delivery channel via SMS gateway compromise or OAuth token theft to send fake verified emergency alerts to the community and third-party agencies.	Public panic, false evacuation instructions, and erosion of community trust in official emergency communications during an active disaster.

#	Component	STRIDE Threat	Threat Description	Impact on Phoenix
ST-05	Community / Auths Feedback (Third-Party Report Submissions)	Spoofing	Attacker impersonates an official agency such as Victoria Police or the Country Fire Authority to submit false high-confidence threat confirmations that carry maximum weight in the model retraining pipeline.	Authoritative-weight false intelligence enters retraining pipeline — AI model classifications shift systematically in attacker's favour.
ST-06	External Sources of Disasters (BoM Feed — Data in Transit)	Tampering	Attacker intercepts the BoM disaster feed in transit using a man-in-the-middle attack and modifies hazard severity ratings — for example, downgrading an Extreme bushfire danger to Low — before the data reaches Phoenix's Data Validation component.	Phoenix fails to elevate its cyber threat monitoring sensitivity for affected regions during a real disaster event — genuine scam and phishing campaigns go undetected.
ST-07	Data Validation (Schema Validation Gate)	Tampering	Attacker crafts malformed or adversarially structured payloads that exploit edge cases in the schema validation logic, passing through the Data Validation component and reaching the stream processing layer with unvalidated malicious content.	Unvalidated attacker-controlled data enters the Phoenix pipeline — AI model and correlation engine process false intelligence without triggering any security alarms.
ST-08	Stream Processing (Kafka / Firebase / APIs)	Tampering	Attacker gains access to the Apache Kafka broker through a compromised service account or network misconfiguration and injects malicious messages directly into Kafka topics — after Data Validation has already run — introducing false data into the processing pipeline.	Attacker-controlled data reaches the AI model and Correlation Engine undetected — risk scores can be manipulated without triggering ingestion-layer security controls.
ST-09	AI Model Processing (Threat Classification / Scam Detection)	Tampering	Attacker crafts adversarially engineered scam messages — exploiting weaknesses in Phoenix's NLP-based threat classification model — that are consistently misclassified as benign despite being genuine threats. This is achieved through systematic black-box probing of model decision boundaries.	Genuine disaster scam content evades detection — Phoenix issues no alerts for active phishing campaigns targeting disaster-affected communities.
ST-10	Scam DB / Cyber Threat DB (Database Records)	Tampering	Attacker exploits a SQL injection vulnerability or insider access to directly modify stored scam records and threat intelligence entries in the Scam DB or Cyber Threat DB, corrupting the historical data that Phoenix's AI model uses for classification and training.	AI model trained and classified against corrupted data — systematic degradation of detection accuracy across all threat categories.
ST-11	Correlation Engine (Cross-refer Scams & Disasters / Risk Scoring)	Tampering	Attacker injects carefully crafted false inputs — manipulated timestamp or geolocation metadata — into the Correlation Engine's data feeds to prevent correct hazard-to-threat cross-referencing, causing the engine to produce a falsely low risk score during a real disaster event.	Genuine disaster-correlated cyber threats are not escalated to DMT review — community alerts are suppressed during active attacks.
ST-12	Model Retraining (Feedback Collection Loop)	Tampering	Attacker executes a feedback timing attack — submitting a large coordinated volume of adversarially crafted feedback immediately before a scheduled model retraining cycle — to maximise the corruption of the next retrained model version before the malicious submissions are detected.	Retrained model immediately adopts corrupted classifications — Phoenix's ability to detect disaster scams is systematically degraded after every retraining cycle.
ST-13	DMT Review (Critical Cases — Alert Approval)	Repudiation	A malicious DMT reviewer deliberately classifies a genuine high-risk threat as a false positive, suppressing an alert, then denies having seen or actioned the threat. Without an immutable audit trail, there is no evidence to contradict the denial.	No accountability for critical alert suppression decisions — genuine threats go unaddressed during active disasters with no traceable responsibility.
ST-14	Alert System (Alert Dispatch Log)	Repudiation	An attacker who has suppressed a genuine alert, or an insider who issued a false one, claims no alert was sent or received. Without a tamper-evident delivery log, communities and agencies cannot verify whether a critical warning was dispatched.	Inability to verify alert delivery during disaster investigations — communities may not know whether they failed to receive a warning or whether it was never sent.
ST-15	Scam DB / Cyber Threat DB (Database Access Log)	Repudiation	An insider or attacker who has modified or deleted database records also alters or deletes the database access logs to erase evidence of the intrusion, making forensic investigation impossible.	No ability to determine which records were changed, when, or by whom — undermines all post-incident investigation and accountability.
ST-16	Data Validation (Validation Decision Log)	Repudiation	No persistent record is maintained of which data packets passed or failed validation checks. After a data quality incident, there is no way to determine whether malicious data entered the pipeline through a validation bypass or through a legitimate source.	Post-incident forensic investigation cannot trace the origin of corrupted pipeline data — preventing identification of the attack vector.

#	Component	STRIDE Threat	Threat Description	Impact on Phoenix
ST-17	Scam DB / Cyber Threat DB (Personal Data of Disaster Victims)	Information Disclosure	Attacker exploits an unsecured database connection, SQL injection vulnerability, or misconfigured access control to extract personal records of disaster victims — names, addresses, phone numbers, health information — stored in the Scam DB or Cyber Threat DB.	Privacy violation and identity theft of vulnerable disaster-affected individuals — loss of community trust in Phoenix and government disaster management systems.
ST-18	AI Model Processing (Model Inversion / Membership Inference)	Information Disclosure	Attacker repeatedly queries Phoenix's AI model with carefully chosen inputs and analyses output confidence scores to reconstruct information about the training dataset — revealing which scam patterns and threat indicators were used during model training.	Attacker learns exactly which scam types Phoenix is trained to detect — enabling precise model evasion by designing content that falls outside known training patterns.
ST-19	Stream Processing (Firebase Community Interface)	Information Disclosure	Misconfigured Firebase security rules expose community feedback records — including disaster-affected residents' contact details, location data, and submitted threat reports — to unauthorised read access by external parties.	Personal data of community members submitting threat reports during a disaster is exposed — discourages future community engagement and violates privacy obligations.
ST-20	Alert System (Alert Delivery API Endpoints)	Denial of Service	Attacker floods the Phoenix alert delivery API with a high volume of requests during an active disaster, exhausting rate limits and preventing genuine alert commands from being processed — silently blocking community warning delivery.	Community members and emergency services do not receive critical safety warnings during the most dangerous period of a disaster event.
ST-21	Stream Processing (Kafka / Firebase)	Denial of Service	Attacker floods Apache Kafka topics with massive message volumes to exhaust broker capacity — particularly effective during a disaster when data volumes are already elevated — causing legitimate message processing to slow or halt entirely.	AI model and Correlation Engine receive no data — Phoenix loses real-time threat detection capability at precisely the moment disaster-context cyber threats are peaking.
ST-22	External Sources of Disasters & Scams (Data Fetch Endpoints)	Denial of Service	Attacker launches a denial-of-service attack against the BoM, Scamwatch, or ASD API endpoints that Phoenix depends on for real-time disaster and threat data — taking those feeds offline and creating dangerous blind spots in Phoenix's monitoring.	Phoenix operates without live disaster or threat intelligence — risk scoring and alert generation are based on stale data during an active disaster event.
ST-23	Failure to Fetch / Retry (Retry Mechanism)	Denial of Service	Attacker deliberately triggers repeated data fetch failures, causing the retry mechanism to enter a continuous loop that exhausts system CPU and memory resources — effectively creating a self-inflicted denial of service through Phoenix's own resilience mechanism.	System resources exhausted during an active disaster — other pipeline components slow or become unresponsive while the retry loop consumes available capacity.
ST-24	Scam DB / Cyber Threat DB (Ransomware Encryption)	Denial of Service	Organised cybercrime group deploys ransomware that encrypts the Scam DB and Cyber Threat DB, rendering all historical threat intelligence and scam records inaccessible and halting AI model processing and Correlation Engine operations.	Complete loss of Phoenix's threat intelligence capability during a disaster — no historical context for AI classification; potential ransom demand under disaster-pressure conditions.
ST-25	DMT User Login (Authentication / Session Management)	Elevation of Privilege	Attacker who has compromised a Read-Only Analyst account exploits a privilege escalation vulnerability — session fixation, JWT token manipulation, or RBAC misconfiguration — to elevate their access to DMT Reviewer or System Administrator level without valid authorisation.	Full control of Phoenix alert approval, model configuration, and data source management — all high-impact functions become accessible through a single compromised low-privilege account.
ST-26	Role-Based Access Control (RBAC Configuration)	Elevation of Privilege	A misconfigured or overly permissive RBAC policy grants users' access beyond their authorised role scope — for example, a DMT Reviewer gaining System Administrator permissions — or allows an insider to exploit a configuration gap to self-assign elevated privileges.	Insider threat with inflated permissions can suppress genuine alerts, alter model parameters, introduce corrupted feedback, or exfiltrate threat intelligence with minimal detection risk.
ST-27	Stream Processing (Kafka Broker / Firebase Admin)	Elevation of Privilege	Attacker exploits a vulnerability in Kafka's authentication configuration or a misconfigured Firebase admin SDK to gain producer or admin-level access to the message broker — beyond their authorised consumer-only role — enabling them to inject or consume unrestricted message traffic.	Attacker with elevated broker access can inject malicious data across all Kafka topics or read sensitive community feedback data — effectively becoming a trusted internal component of the pipeline.

STRIDE Summary — Threat Count by Category

STRIDE Category	Count	Most Affected PHOENIX Components	Highest Risk
Spoofing (S)	5	DMT User Login, Alert System, Community Feedback	Critical
Tampering (T)	7	Scam DB / Cyber Threat DB, AI Model, Data Feeds	Critical
Repudiation (R)	4	DMT Review, Alert System, Database Logs	High
Information Disclosure (I)	3	Scam DB, AI Model, Firebase	Critical
Denial of Service (D)	5	Alert System, Kafka, Database (Ransomware)	Critical
Elevation of Privilege (E)	3	DMT Login, RBAC, Stream Processing	Critical

Spoofing Threats

Spoofing represents the most immediately dangerous threat category for Phoenix, because it undermines the fundamental trustworthiness of the system's inputs, outputs, and user identities. The consequences of a successful spoofing attack are not confined to a single component. They cascade through the entire pipeline. An attacker who spoofs the Bureau of Meteorology data feed causes Phoenix to make threat assessments based on a false picture of the disaster landscape; an attacker who spoofs the DMT user login gains direct control over alert dispatch; an attacker who spoofs the alert delivery channel puts false emergency instructions into the hands of disaster-affected communities. The 2019 compromise of Australia's Early Warning Network where stolen credentials were used to impersonate an authorised operator and send fake emergency alerts to thousands of Queensland residents demonstrates that spoofing attacks against emergency management systems are not theoretical risks in the Australian context (Dataset Row 16, Chakraborty et al., 2024). More recently, in 2025, fraudulent SMS messages impersonating Centrelink and the Queensland Premier's official disaster relief appeal reached disaster-affected communities through what appeared to be legitimate government channels (Dataset Row 22). Phoenix mitigates spoofing threats through layered identity verification: API key validation and certificate pinning on external data feeds, multi-factor authentication on the DMT login, digital signatures on all outgoing alerts, and cryptographic verification requirements on official agency feedback submissions (Azambuja et al., 2023).

Tampering Threats

Tampering is the most pervasive threat category across the Phoenix architecture which affecting seven distinct DFD components and representing the primary risk to the system's data integrity at every stage of its pipeline. Unlike spoofing, which targets identity, tampering targets data and in a system whose entire value depends on the accuracy of its threat intelligence and risk scores, data integrity is the foundation on which everything else rests. The man-in-the-middle tampering threat against the BoM disaster data feed is particularly significant for Phoenix's core mission: if an attacker can modify hazard severity ratings before they reach the Data Validation component, Phoenix's disaster-context sensitivity, the feature that makes it fundamentally different from general-purpose threat intelligence systems is neutralised at the source (Chakraborty et al., 2024; Dataset Row 54,). At the database layer, SQL injection and insider tampering with the Scam DB and Cyber Threat DB represent a Critical severity threat because the AI model's classifications are only as reliable as the historical data it has been trained against. The Fire Rescue Victoria ransomware incident demonstrates that Australian emergency services infrastructure is an actively targeted tampering objective and that the consequences, once systems are compromised, can persist for months (Chirgwin, 2023; Dataset Row 12). Phoenix's core mitigations against tampering are cryptographic in nature: hash verification of incoming feeds, TLS 1.3 encryption in transit, parameterised queries preventing SQL injection, and immutable record versioning in the databases (Spyros et al., 2025).

Repudiation Threats

Repudiation threats are uniquely dangerous in a system designed for public accountability because Phoenix's purpose is to help communities trust official emergency communications and that trust requires demonstrable proof that decisions were made, alerts were sent, and actions were taken. An insider who suppresses a genuine high-risk alert and then denies having reviewed it, a system component that fails without leaving a trace of what data passed through it, or an attacker who erases database access logs after a breach all of these create accountability gaps that are as damaging to Phoenix's institutional credibility as the original attack. The Fire Rescue Victoria incident illustrates this risk: the cyber-attack not only disrupted operations but severely hampered the subsequent investigation because compromised systems could not provide reliable logs of what communications were sent or received during the incident (Chirgwin, 2023). Phoenix addresses repudiation through a commitment to comprehensive, tamper-evident audit logging at every critical decision point: every validation pass or failure, every Correlation Engine risk score and the inputs that produced it, every DMT review decision with reviewer identity and rationale, and every alert dispatched with delivery confirmation. These logs must be stored in write-protected systems that are architecturally separate from the components they are logging by ensuring that compromising a pipeline component does not simultaneously destroy its audit trail (Azambuja et al., 2023; Spyros et al., 2025).

Information Disclosure Threats

Information disclosure threats in Phoenix carry a dimension of harm that extends well beyond operational impact because the personal data that Phoenix processes belong to some of Australia's most vulnerable people: disaster-affected residents submitting threat reports, community members flagging suspicious activity, and victims whose personal details appear in scam records. The 2025 exposure of personal data belonging to 3,000 NSW flood victims uploaded to ChatGPT by a contractor with access to the Resilient Homes Program database which demonstrates the precise risk that careless data handling poses in disaster-context systems (Dataset Row 26). At the AI model level, information disclosure through model inversion attacks presents a more subtle but operationally significant threat: if an attacker can reconstruct which scam patterns Phoenix was trained to detect, they can engineer evasion content with precision, transforming information disclosure into a precursor to a much more damaging model evasion campaign (Hunt et al., 2022). Phoenix mitigates information disclosure through data minimisation by storing only what is strictly necessary field-level encryption for sensitive personal data, strict access controls, and differential privacy techniques in the model training pipeline (Azambuja et al., 2023).

Denial of Service Threats

Denial of service threats against Phoenix are particularly consequential because they strike hardest during disaster events precisely when the system's availability is most critical and when infrastructure is already under elevated stress. A DDoS attack against the alert delivery API during an active bushfire evacuation, a Kafka broker flood during the peak data ingestion period of a major flood event, or ransomware encryption of the Scam DB at the moment when community scam reports are surging, all of these attacks are most effective when Phoenix and the emergency services that depend on it have the least capacity to respond. The December 2022 ransomware attack on Fire Rescue Victoria which rendered dispatch systems, email, and phones inoperable across 85 stations for months is the most direct precedent for this threat category in Australian emergency services (Chirgwin, 2023; Dataset Row 12). The 2024 DDoS attacks documented in the Sprint 1 CTI dataset confirm that emergency response websites are explicitly targeted by threat actors who understand the timing dimension of this attack vector (Dataset Row 48). Phoenix's resilience against denial of service is layered: DDoS protection on public-facing endpoints, Kafka topic quotas and auto-scaling for stream processing, cached feed copies with defined staleness thresholds, redundant alert delivery channels so no single disruption blocks all communications, and rapid database recovery procedures with tested restoration times (Azambuja et al., 2023).

Elevation of Privilege Threats

Elevation of privilege threats in Phoenix represent the attack scenario in which an attacker or malicious insider transitions from a position of limited access to one of systemic control and in a system with the alert-dispatch and model-configuration capabilities of Phoenix, that transition is uniquely dangerous. A Read-Only Analyst who successfully escalates to System Administrator gains the ability to suppress alerts, alter model parameters, introduce corrupted feedback into the retraining pipeline, and exfiltrate threat intelligence all through the system's own normal functionality, leaving no obvious signature of an external attack. The most insidious form of this threat is the RBAC misconfiguration: a permission policy that appears correct on paper but contains a gap that allows an insider to self-assign elevated privileges without triggering any security alert. Spyros et al. (2025) identify privilege escalation as a top-tier threat in AI-based Cyber Threat Intelligence management systems, and the principle of least privilege by granting each role only the minimum permissions necessary to perform its defined function is the foundational control. Phoenix enforces this through server-side role verification at every privileged operation, privilege-change alerts, separation of duties for the highest-risk functions (alert approval and model configuration), and regular RBAC audits against a defined permission matrix. Every administrative action is logged with full identity attribution, ensuring that even successful privilege escalation leaves a traceable record (Azambuja et al., 2023; Spyros et al., 2025).

References

Australian Taxation Office. (2020). SMS scam targeting natural disaster victims promises 8% bonus on tax returns. https://www.ato.gov.au/media-centre/sms-scam-targeting-natural-disaster-victims-promises-8-percent-bonus-on-taxreturns

Azambuja, A. J. G., Plesker, C., Schützer, K., Anderl, R., Schleich, B., & Almeida, V. R. (2023). Artificial intelligence-based cyber security in the context of Industry 4.0 — A survey. Electronics, 12(8). https://doi.org/10.3390/electronics12081920

Chakraborty, S., Mombeshora, E. M., Clark, K. P., & Mbavarira, T. S. (2024). Understanding of cyber-attack vulnerabilities during natural disasters and discussing a cyber-attack resiliency framework. In SoutheastCon 2024. https://doi.org/10.1109/SoutheastCon52093.2024.10500233

Chirgwin, R. (2023). Fire Rescue Victoria still hampered by December 2022 cyber attack. iTnews. https://www.itnews.com.au/news/fire-rescue-victoria-still-hampered-by-december-2022-cyber-attack-597024

Hunt, K., Agarwal, P., & Zhuang, J. (2022). Monitoring misinformation on Twitter during crisis events: A machine learning approach. Risk Analysis, 42(8), 1728–1748. https://doi.org/10.1111/risa.13634

Microsoft. (2024). STRIDE threat model. Microsoft Security Documentation. https://learn.microsoft.com/en-us/azure/security/develop/threat-modeling-tool-threats

Nguyen, K., & Bogle, A. (2020). The bushfire lies spreading "wildly" on social media. ABC News. https://www.abc.net.au/news/2020-01-08/fires-misinformation-being-spread-through-social-media/11846434

Salley, C. J., Mohammadi, N., & Taylor, J. E. (2023). Safeguarding infrastructure from cyber threats with NLP-based information retrieval. In 2023 Winter Simulation Conference. https://doi.org/10.1109/WSC60868.2023.10407248

Scamwatch. (2020). Bushfires and scams. Australian Competition and Consumer Commission. https://www.scamwatch.gov.au/about-us/news-and-alerts/bushfires-and-scams-0

Spyros, A., Koritsas, I., Papoutsis, A., Panagiotou, P., Chatzakou, D., Kavallieros, D., Tsikrika, T., Vrochidis, S., & Kompatsiaris, I. (2025). AI-based holistic framework for cyber threat intelligence management. IEEE Access, 13, 20820–20846. https://doi.org/10.1109/ACCESS.2025.3533084

Vicari, R., & Komendatova, N. (2023). Systematic meta-analysis of research on AI tools to deal with misinformation on social media during natural and anthropogenic hazards and disasters. Humanities and Social Sciences Communications, 10(1), 332. https://doi.org/10.1057/s41599-023-01838-0

Sprint 1 CTI Dataset. (2026). PHOENIX Project Cyber Threat Intelligence Dataset (Sprint 1 — cleaned and finalised by Inderjeet Singh). Hardhat Enterprises, Deakin University. Sprint1_Final_Changes_Highlighted.xlsx